



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

"企业级"恶意程序开发者搅局移动安全

陈宏伟

360烽火实验室
高级安全研究员



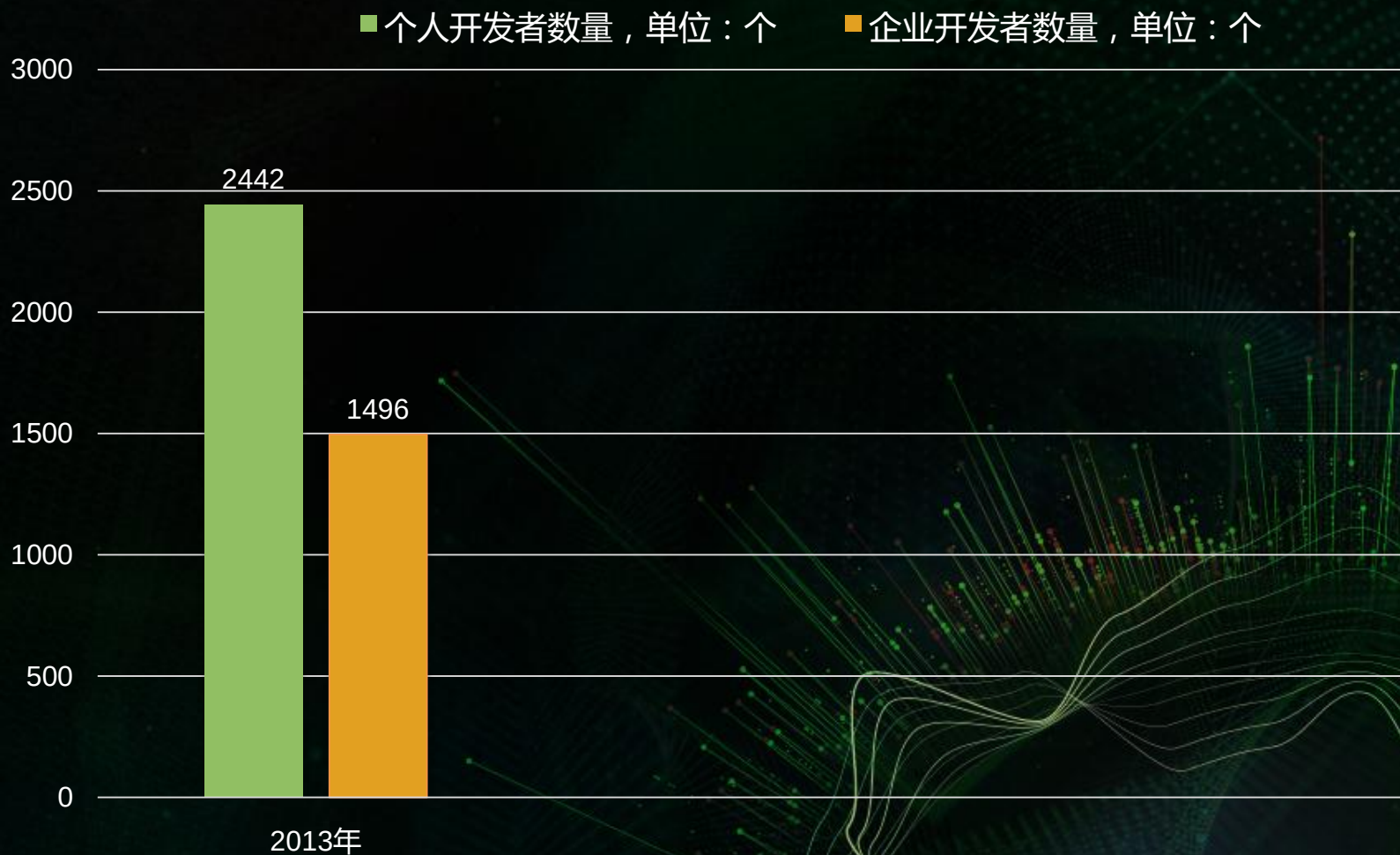
关于我们

360烽火实验室致力于Android病毒分析、移动黑产研究、移动威胁预警以及Android漏洞挖掘等移动安全领域及Android安全生态的深度研究。

实验室为360手机卫士、360手机急救箱、360手机助手等提供核心安全数据和顽固木马清除解决方案。同时也为上百家国内外厂商、应用商店等合作伙伴提供移动应用安全检测服务，全方位守护移动安全。

- 1 移动恶意程序开发者概况**
- 2 “企业” 开发者大显身手**
- 3 恶意开发者之间的“较量”**
- 4 应对策略**

恶意程序开发者概况



数据来源：360移动开放平台

恶意程序开发者概况



中国互联网安全大会



360互联网安全中心



数据来源：360移动开放平台

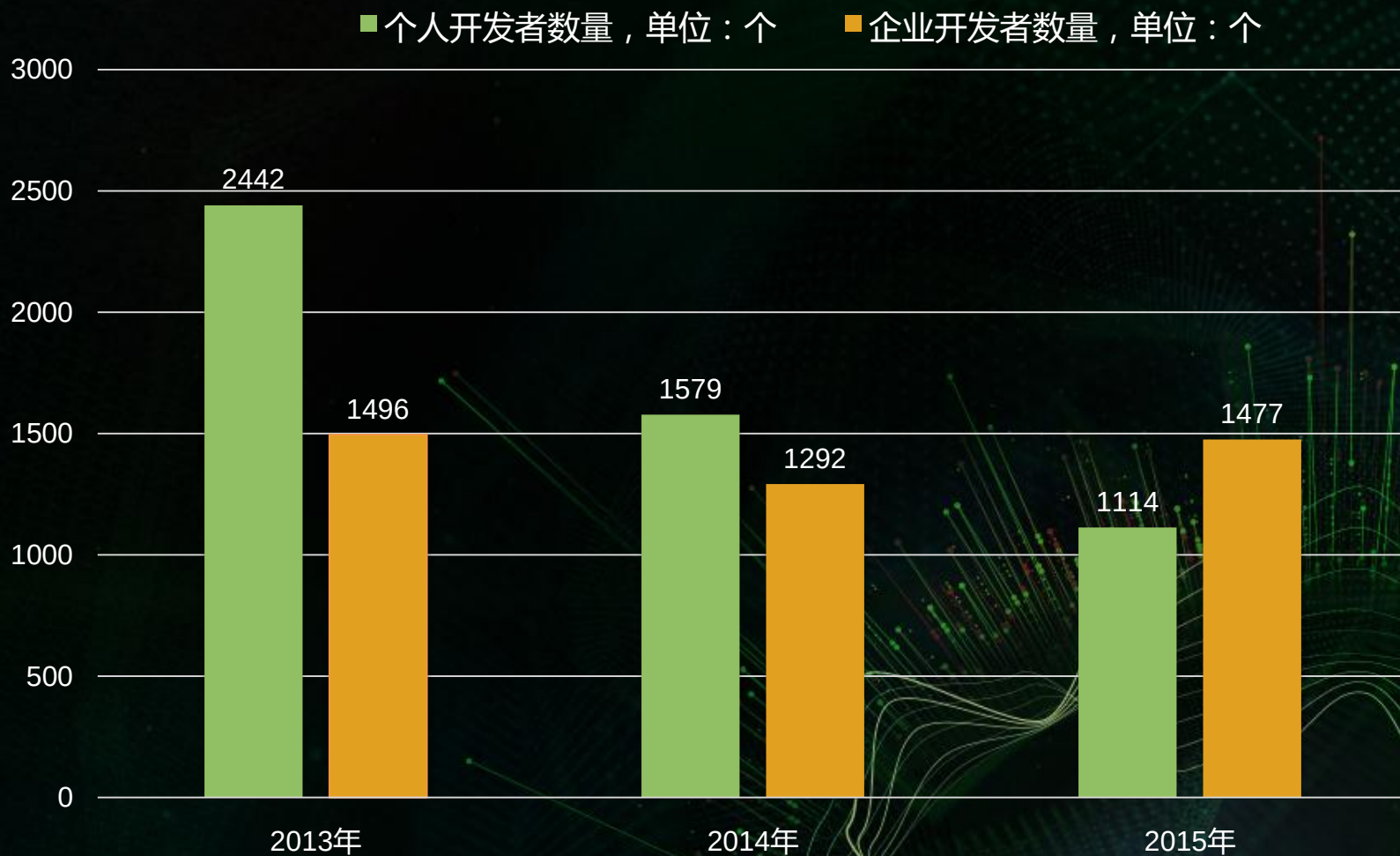
恶意程序开发者概况



中国互联网安全大会



360互联网安全中心



数据来源：360移动开放平台

恶意开发者七宗罪



中国互联网安全大会



360互联网安全中心



- 1 移动恶意程序开发者概况**
- 2 “企业” 开发者大显身手**
- 3 恶意开发者之间的“较量”**
- 4 应对策略**

流量僵尸



中国互联网安全大会



360互联网安全中心

时 间：2015年7月

关键词：游戏、搜索引擎、热搜榜、消耗流量



流量僵尸



中国互联网安全大会



360互联网安全中心

下载

Stream Content

GET /?union=1&from=1012771e&tn=ops1012771e HTTP/1.1
Host: m.hao123.com

Connection: keep-alive

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,
webp,*/*;q=0.8

User-Agent: Mozilla/5.0 (Linux; Android 4.4.4; MI 2S Build/KTU
AppleWebKit/537.36 (KHTML, like Gecko) Version/4.0 Chrome/33.0
Mobile Safari/537.36

Accept-Encoding: gzip,deflate

Accept-Language: zh-CN,en-US;q=0.8

X-Requested-With: cn.opda.android.activity

HTTP/1.1 200 OK

Date: Thu, 16 Jul 2015 11:33:10 GMT

Content-Type: text/html; charset=utf-8

Transfer-Encoding: chunked

Connection: close

Content-Encoding: gzip

Set-Cookie: BAIDUID=74D689E66443E8C11BD1C3860406F7AE:FG=1;
expires=Fri, 15-Jul-16 11:33:10 GMT; max-age=31536000; path=/;
domain=.hao123.com; version=1

P3P: CP=" OTI DSP COR IVA OUR IND COM "

Server: nginx

Entire conversation (24307 bytes)

Find

Save As

Print

☐ ASCII

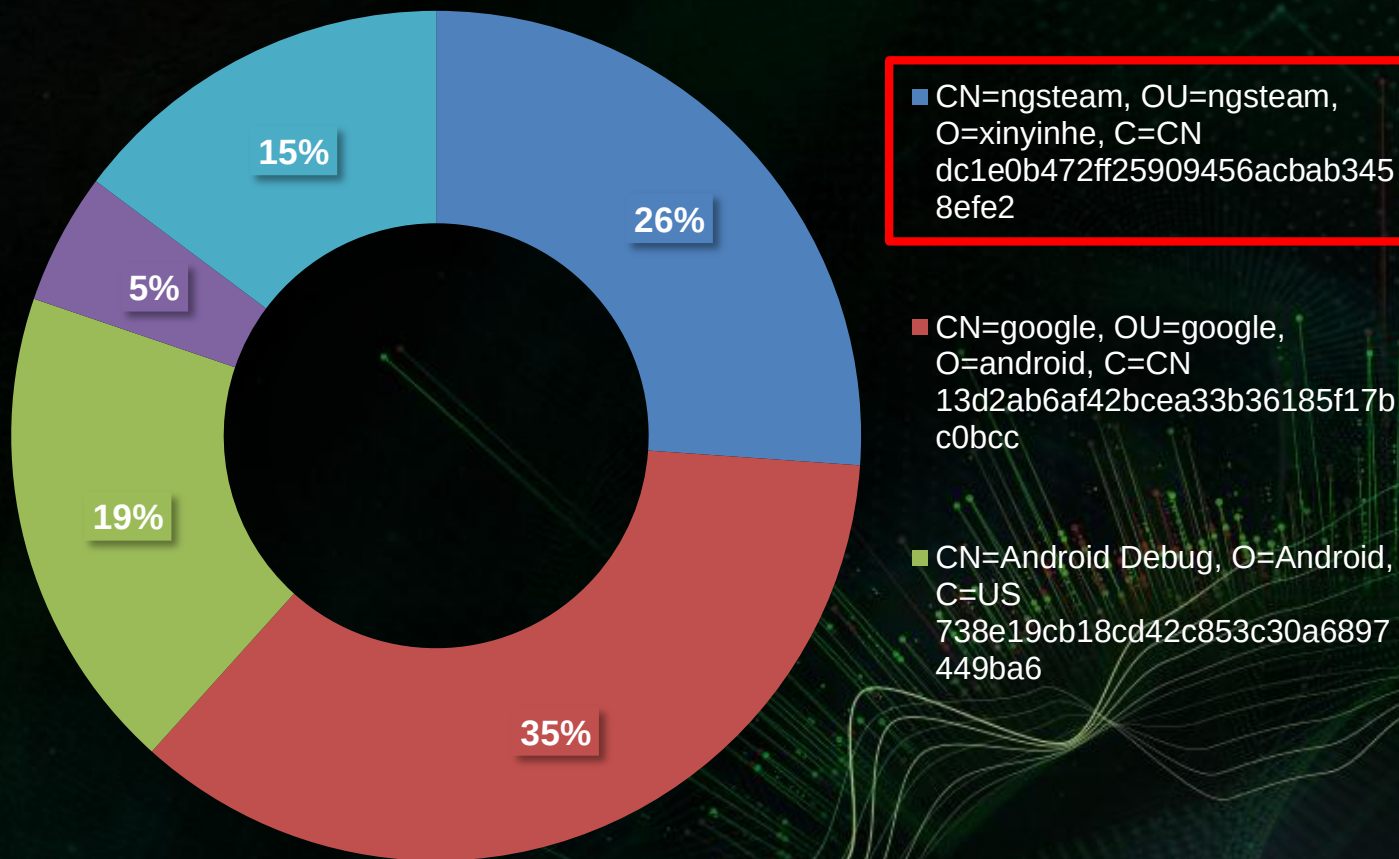
☐ EBCDIC

☐ Hex Dump

☐ C Arrays

技术支持

流量僵尸感染应用签名分布图



时 间：2015年8月

关键词：TimeService、MonkeyTest、Root、反复感染



关于部分手机系统感染病毒及处理方案的公告

发表于 2015-8-21 09:19 发表在 [公告&活动] [置顶](#) [复制链接] [只看楼主] [打印] [上一主题] [下一主题]

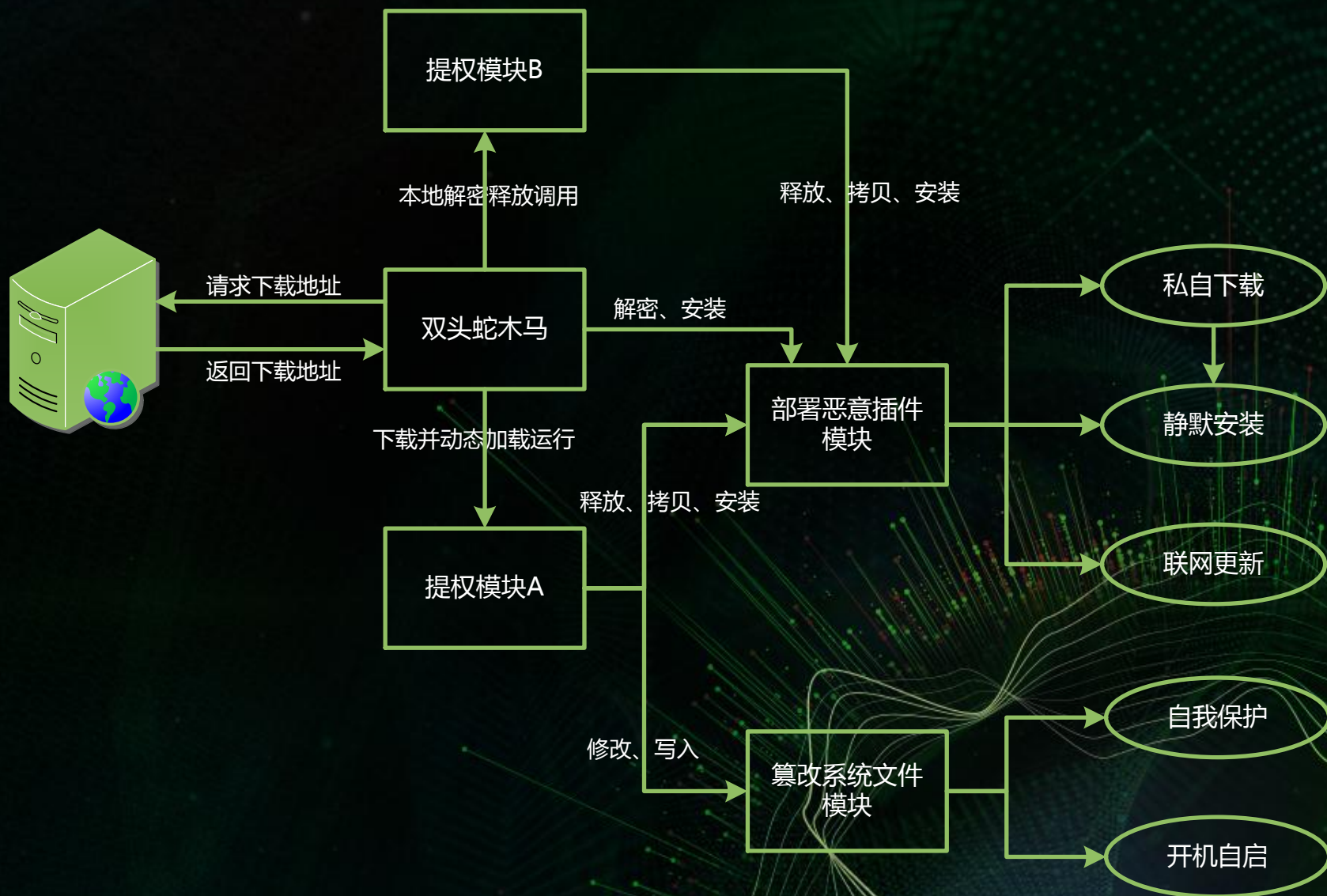


亲爱的神族小伙伴们：

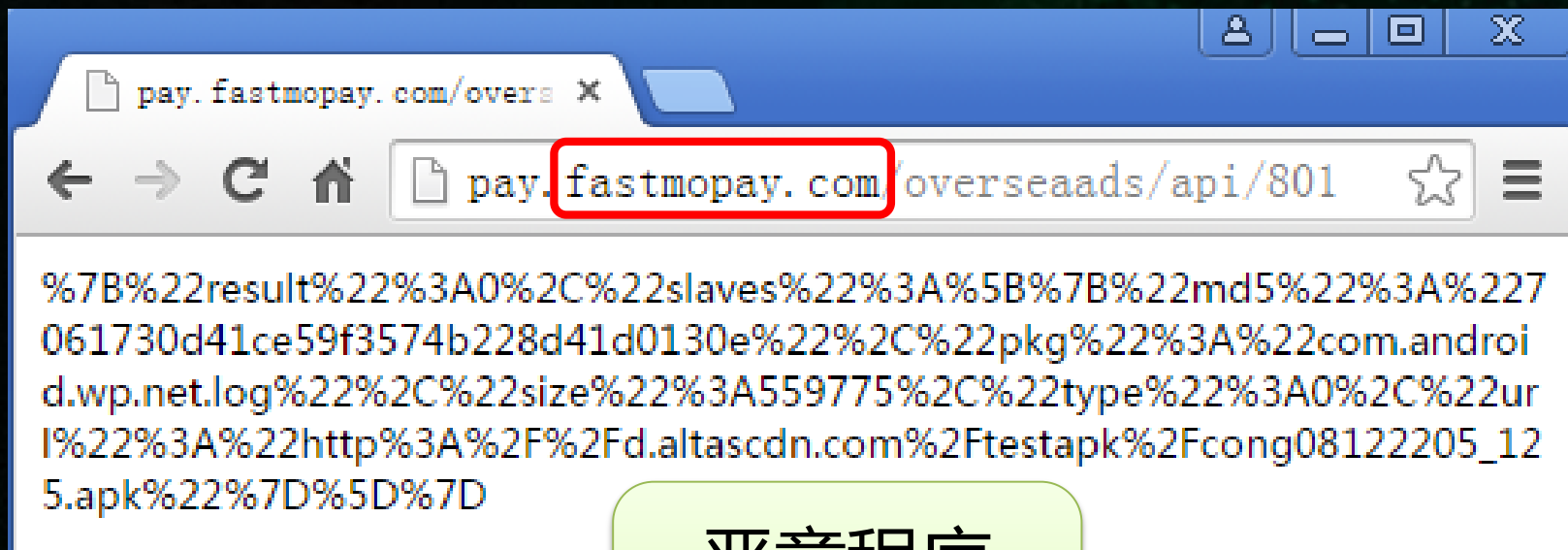
近日，我们的安全工程师在对手机的安全常规监测中，发现有一部分手机因下载第三方带病毒软件，导致手机系统感染病毒，并有可能给部分用户带来经济损失。该病毒通过多种途径扩散，已经在国内外多个品牌的手机上被发现。

手机系统安全团队对病毒展开了全面深入的系统检测分析，并在第一时间将紧急解决方案公布在。现在我们再次将相关处理方案告知已系统感染病毒的用户，建议处理方法：

- 1) 通过杀毒、刷机等方法来解决相应问题。操作办法详见我们在社区公布的帖子<http://bbs.d.com/thread-5002691-1-1.html>
- 2) 对于因此次系统感染病毒遭受经济损失的用户，我们将会近日提供协助解决方案，告知如何处理解决，以确保您的利益不会受损。



[illegible]



恶意程序
MonkeyTest

```
{"result":0,"slaves":  
[{"md5":"7061730d41ce59f3574b228d41d0130e","pkg":"com.android.wp.net.log","size":559775,"type":0,"url":"http://d.altascdn.com/testapk/cong08122205_125.apk"}]}
```

另一个变种联网下载的衍生物中，发现与之前相似结构的网址。

```
package com.android.ngsteamcore.util;

import java.io.File;

public class Constant {
    public static final String APP_ID = "xinyinhe_ngsteam_appid";
    public static final String APP_ID_NEW = "xinyinhe_sys_appid";
    public static final String APP_KEY = "xinyinhe_ngsteam_appkey";
    public static final String APP_KEY_NEW = "xinyinhe_sys_appkey";
    public static final String CLIENT_ID = "client_id";
    public static final int CLIENT_ID_LENGTH = 23;
    public static String DEFAULT_SERVER = null;
    public static String EN_DEFAULT_SERVER = null;
    public static final String FILE_PATH = null;
    public static final String PATH_DELETE = "/pmsg/api/3";
    public static final String PATH_USER_HISPFEEBACK = "/pmsg/api/7";
    public static final String PATH_USER_P = "/pmsg/api/6";
    public static final String PATH_USER_PFEEDBACK = "/pmsg/api/5";
    public static final int SRC_CHECK_U = 2;
    public static final int SRC_COMMAND_SILENCE = 3;
    public static final int SRC_COUNT = 4;
    public static final int SRC_FEEDBACK = 5;
    public static final int SRC_P_INFORMATION = 6;
    public static final int SRC_P_LOG = 7;
    public static final int SRC_QUERY = 9;
    public static final int SRC_QUERY_AD = 1;
    public static fi
    public static fi
    public static fi
    public static St

    static {
        Constant.FILE_PATH = File.separator + "Andriod\\ngsteamcore\\data"
        "cr" + File.separator;
        Constant.DEFAULT_SERVER = "http://msg.aolmob.com/";
        Constant.EN_DEFAULT_SERVER = "http://msg.zolmob.com/";
        Constant.TRACK_AD_SERVER = "http://pay.fastmopay.com/overseasads/api/102";
    }
}
```

fastmopay.com

2015年9月22日，FireEye在其博客也发布了对该恶意程序的分析报告。
幕后的作者指向一家中国公司。

GUARANTEED CLICKS: MOBILE APP COMPANY TAKES CONTROL OF ANDROID PHONES

September 22, 2015 | by Yulong Zhang, Zhaofeng Chen, Yong Kang | Vulnerabilities, Threat Research



- There are simplified Chinese characters and Chinese pinyin in the code, so the attacker may be coming from China.
- One of the popular certificate has the CN field as "ngsteam" ("ng" stands for "New Galaxy" the English translation of "xinyinhe") and the O field is "xinyinhe".
- The root exploit payload, Root Master, has someone with email in xinyinhe.com domain participating in the developing.
- xinyinhe.com has a subdomain named root.xinyinhe.com, serving root tools similar to the payload used in the samples.

/ spreading
attack is
aims to be

某公司的“黑历史”



中国互联网安全大会



360互联网安全中心

当前位置：白鲸社区 > 公司 > 深圳市[模糊]技术有限公司



NGEmobi **V认证**

纠错

全球应用推广，移动流量变现，免费流量交换

暂无

北京市朝阳区望京SOHO塔[模糊]

公司介绍:

NGEmobi成立于2013年6月21日，在北京、深圳、上海，新加坡拥有分公司和办事机构，是面向全球的游戏发行和计费平台，立足中国面向全球提供游戏发行和计费的解决方案的互联网公司。公司拥有精准广告营销平台，APP工具矩阵，方案商以及超过5个国家的运营商计费平台等四大核心能力。包括精准化效果营销广告服务平台ADS PLUS，超过1.2亿用户的Fast cleaner等应用。和多个厂商和方案商海外拓展建立密切的联系。在印度、越南、泰国马来西亚等国家和当地运营商建立密切的合作联系。

2014年11月NGEmobi以估值1亿美金获得君联资本的2000万美金的A轮融资。在短短一年的时间内，公司完成了从建立到A轮融资估值1亿美金的傲人业绩，创造了奇迹般的50倍的增长。公司始终坚持“激情、速度、创新、学习”的企业理念，始终坚持以用户为中心的服务体系，立足中国面向全球，立志为游戏发行创造更大价值。

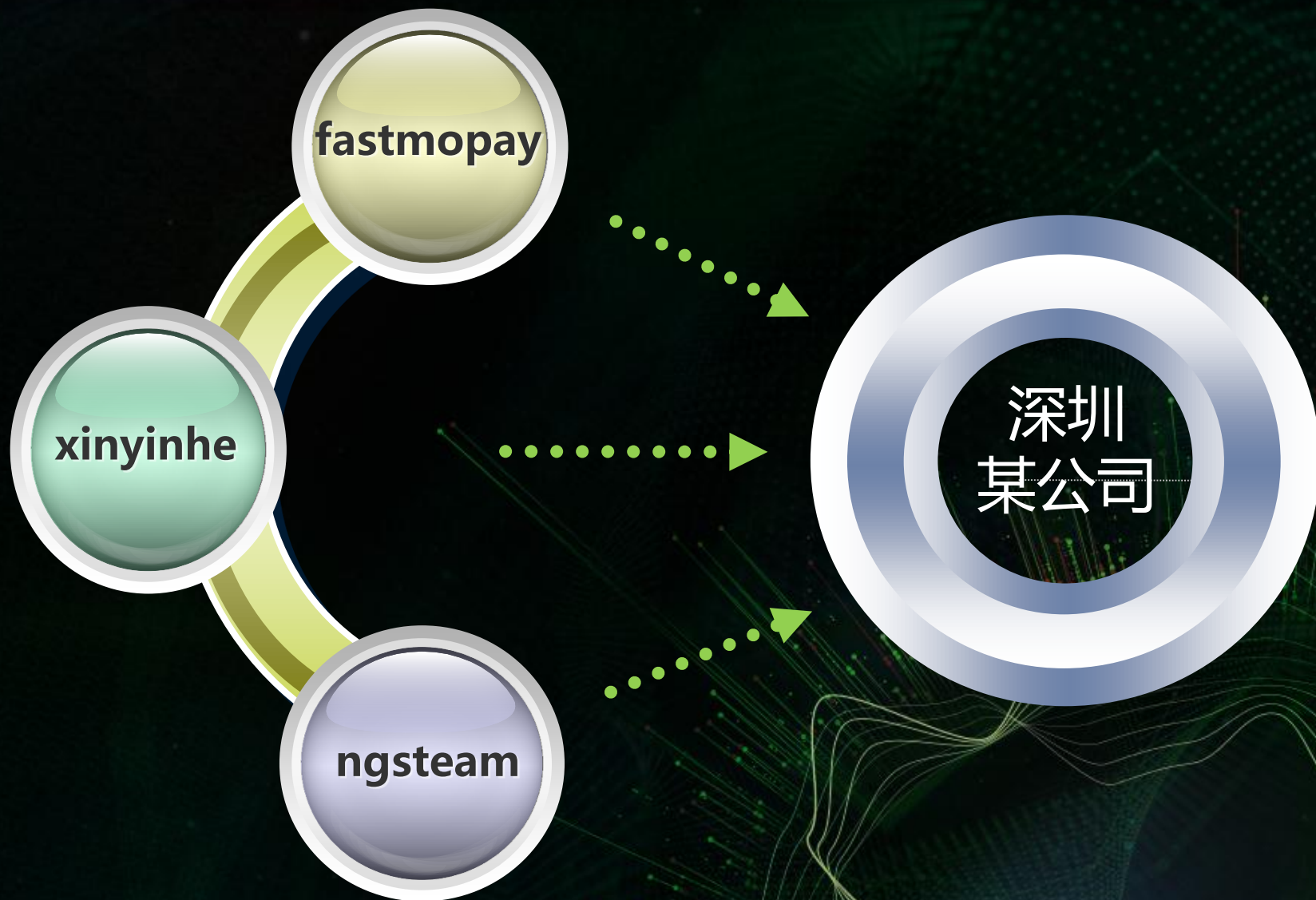
幕后黑手



中国互联网络安全大会



360互联网安全中心



某公司的“黑历史”

在哪里

公司总部设在北京
在广东、上海等地设有销售代理

多少人

员工人数在100人左右，其中技术研发人员在10人左右
鼎盛时期多达50人，其余人员以销售和运营为主

干什么

线上渠道：广告推广，应用计费，转卖计费渠道
线下渠道：应用预装，刷机

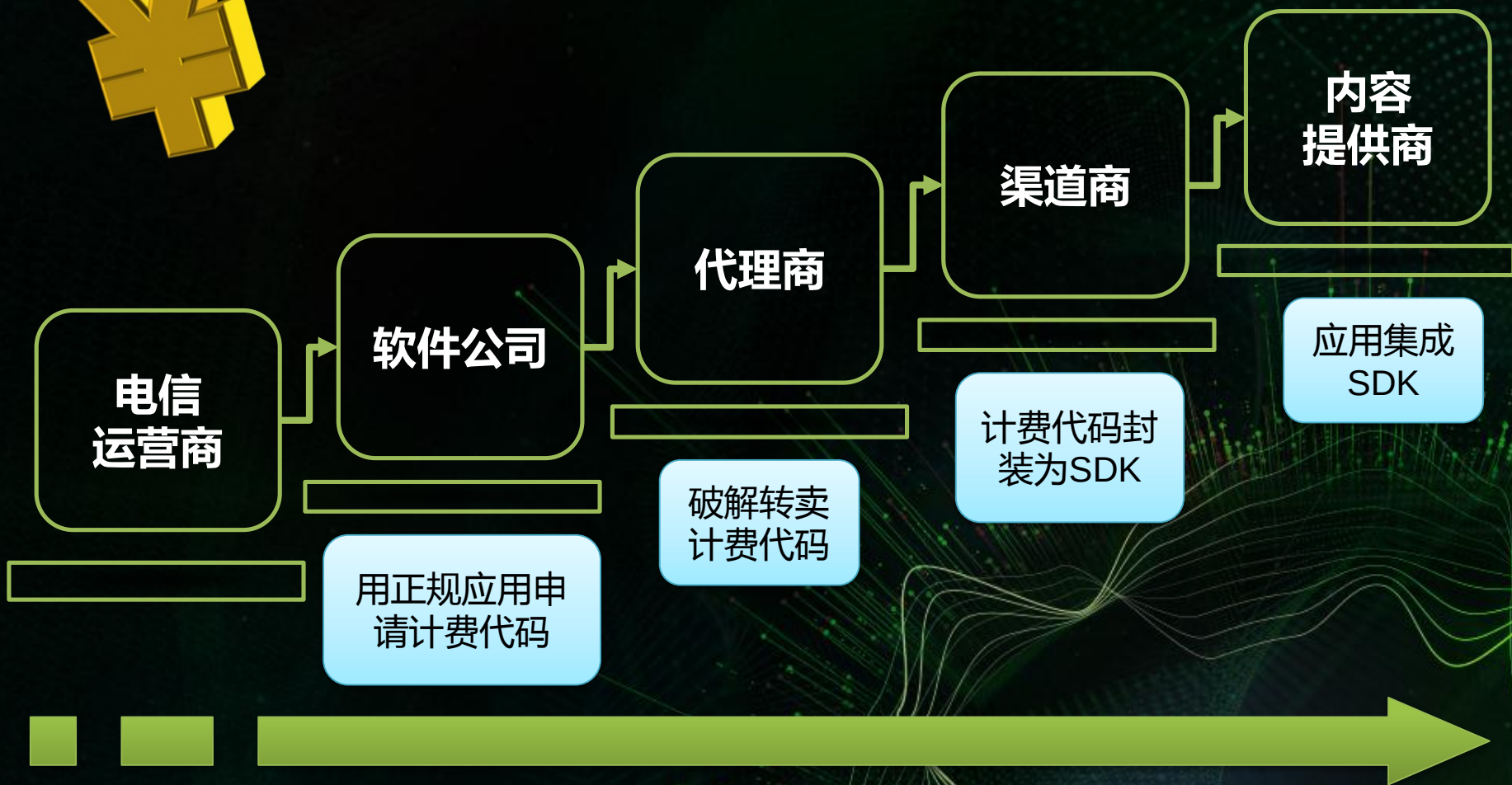
“暗扣” 产业链



中国互联网安全大会



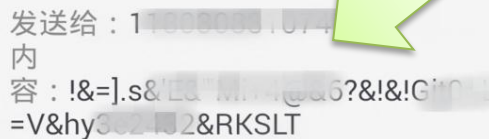
360互联网安全中心



360互联网安全中心

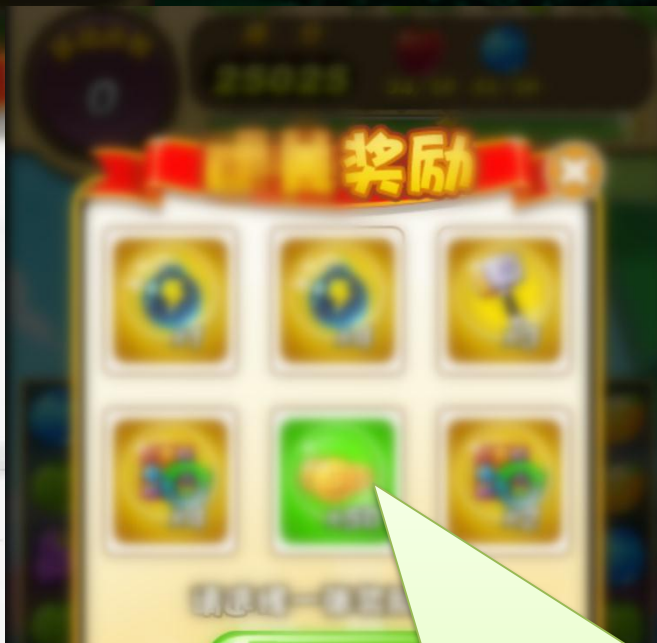


用击



点击领取您将通过短信方式支付 十 元

使用自己的“厂



扣
角
认
信

每个用户的购买的价格为1元
用户误点的概率平均为10%
每个扣费短信的金额在10元以上



流量僵尸

关键词：

- 1个人
- 3天
- 5,000,000次
- 100,000次

幽灵疑云

关键词：

- 海外
- Root大师
- 误抓取

真实的谎言



中国互联网安全大会



360互联网安全中心

的游戏发行和计费平台，立足中国面向全球

游戏二次打包

用于暗扣的SDK

同一个世界
同一款病毒

谜一样的
推广量

以用户为中心

立足中国面向全球，立志为游戏发行创造

- 1 移动恶意程序开发者概况**
- 2 “企业” 开发者大显身手**
- 3 恶意开发者之间的“较量”**
- 4 应对策略**

个人和小规模团队的“弱点”



中国互联网安全大会



360互联网安全中心

技术
深度

功能较为单一

极少有技术难度

传播
方式

渠道单一

通过社交软件、
论坛、贴吧传播

传播
范围

影响范围比较小

多为点到点传播，
传播能力有限

企业开发团队的“优势”



中国互联网安全大会



360互联网安全中心

技术
深度

传播
方式

传播
范围

功能复杂

有一定技术难度，大多采用反射、混淆、加密等对抗手段，多采用动态加载的方式，自带提权模块

渠道多样

例如嵌入SDK、ROM预置等。

影响能力较强

具备大面积传播的能力。

企业开发团队的“尴尬”



中国互联网安全大会



360互联网安全中心

外部环境

- 看似风平浪静，实则暗流涌动
- 公司之间竞争激烈，尔虞我诈
- 停不了的攻击，完不了的举报

企业内部

- 内部缺乏信任，勾心斗角
- 老板唯利是图，处处算计
- 员工欺上瞒下，闷声发财

企业开发团队众生相



中国互联网安全大会



360互联网安全中心



精明的老板

- 创业，入股，降工资
- 老板，销售，客户，运营

机制的员工

- 偷梁换柱
- 手到擒（钱）来

悲催的团队

- 产品经理的噩梦
- 收购==终结

- 1 移动恶意程序开发者概况**
- 2 “企业” 开发者大显身手**
- 3 恶意开发者之间的“较量”**
- 4 应对策略**

应对策略



中国互联网安全大会



360互联网安全中心

谨慎选择植入的SDK
留意SDK所需要的权限

开发者

运营商

加强对服务提供商的监管
加强计费渠道的审查和监管。

政府机构

建立健全相关法律法规
加大打击和处罚的力度
提高作恶的成本

应用市场

加强开发者的审查
加强应用上架前的安全检查
从正规渠道获取应用

手机用户

从正规市场下载应用
谨慎点击广告
安装手机安全软件
保持更新

手机厂商

及时为用户推送安全更新
增强对隐私数据的保护

应对策略

谢谢



中国互联网络安全大会



360互联网安全中心

